23 April 2026

WEB APPLICATION VULNERABILITY ASSESSMENT REPORT

Target Website:http://demo.testfire.net

Prepared By:
DiyaMol Sabu

Tools Used:
Nmap
OWASP ZAP

OBJECTIVE

The objective of this assessment is to analyze the publicly accessible website demo.testfire.net for common security misconfigurations and vulnerabilities using passive security testing methods.

This assessment **aims** to:

- Identify exposed services
- Detect missing security configurations
- Classify risk levels
- Provide clear remediation recommendations
- Improve overall security posture

SCOPE OF TESTING

Target Website:
http://demo.testfire.net

Scope Included:

- Public-facing pages only
- Passive vulnerability scanning
- Header inspection
- Configuration analysis
- Non-intrusive testing methods

Out of Scope:

- Exploitation
- Brute force attacks
- Denial-of-Service attacks
- Any harmful activity

TOOLS USED

The following tools were used during the assessment:

1. Nmap
Used for detecting open ports and services.

2. **OWASP ZAP**
Used for passive vulnerability scanning.

3. SecurityHeaders.com
Used for analyzing HTTP security headers.

4. Browser Developer Tools
Used for inspecting response headers and cookies.

NETWORK SCAN RESULTS (NMAP)

PORT	VERSION DETECTED	SEVERITY	DESCRIPTION	RECOMMENDATION
80	Apache Tomcat/Coyote JSP engine 1.1	Medium	HTTP service is running on port 80, which may allow unencrypted communication	Use HTTPS and redirect HTTP traffic to HTTPS.
443	Apache Tomcat/Coyote JSP engine 1.1	Low	HTTPS service detected, which supports encrypted communication.	Ensure SSL/TLS certificates are properly configured.
8080	Apache Tomcat/Coyote JSP engine 1.1	Medium	Alternate HTTP service running on port 8080, which may expose additional services.	Restrict access or secure unused services.

```
Session  Actions  Edit  View  Help
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~]
└─$ nmap -sV demo.testfire.net
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-24 10:22 +0530
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.083s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE   VERSION
80/tcp   open   http      Apache Tomcat/Coyote JSP engine 1.1
443/tcp  open   ssl/http  Apache Tomcat/Coyote JSP engine 1.1
8080/tcp open   http      Apache Tomcat/Coyote JSP engine 1.1
8443/tcp closed https-alt

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
```

Nmap output screenshot

VULNERABILITY FINDINGS

Name	Risk Level	Number of Instances
Absence of Anti-CSRF Tokens	Medium	3
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Missing Anti-clickjacking Header	Medium	Systemic
Sub Resource Integrity Attribute Missing	Medium	1
Cookie without SameSite Attribute	Low	3
Cross-Domain JavaScript Source File Inclusion	Low	1
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	Systemic
Strict-Transport-Security Header Not Set	Low	1
Timestamp Disclosure - Unix	Low	3
X-Content-Type-Options Header Missing	Low	Systemic
Information Disclosure - Suspicious Comments	Informational	6
Modern Web Application	Informational	4
Retrieved from Cache	Informational	1
Session Management Response Identified	Informational	3

Remediation:
The following actions are recommended to fix the identified vulnerabilities:

- **Absence of Anti-CSRF Tokens**
  Add CSRF tokens to all forms to prevent unauthorized requests.
- **CSP Header Not Set**
  Implement a Content-Security-Policy (CSP) header to prevent Cross-Site Scripting (XSS) attacks.
- **Missing Anti-clickjacking Header**
  Add X-Frame-Options header to protect against clickjacking attacks.
- **Cookie Without SameSite Attribute**
  Configure cookies with SameSite=Strict or SameSite=Lax to improve session security.
- **Server Leaks Version Information**
  Disable server version details to prevent attackers from identifying system vulnerabilities.
- **Site Using HTTP Instead of HTTPS**
  Enable HTTPS and redirect HTTP traffic to secure encrypted communication.

FIGURE 1: ABSENCE OF ANTI-CSRF TOKENS

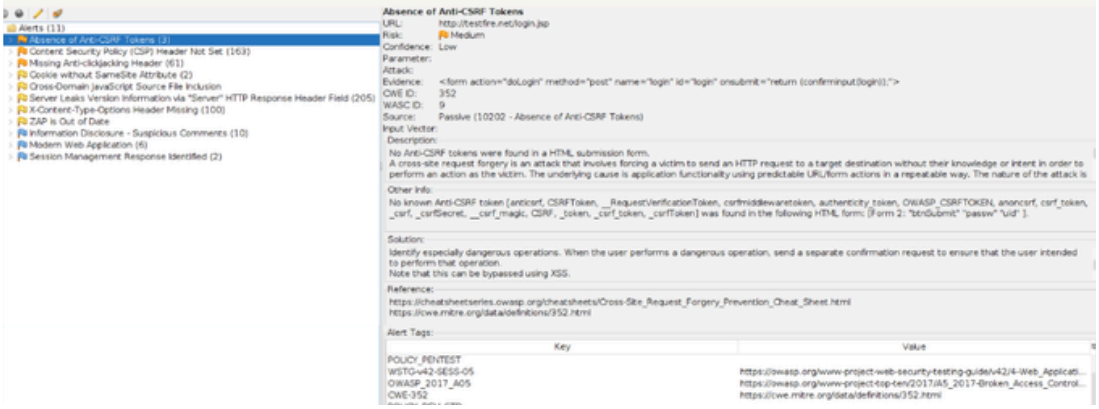
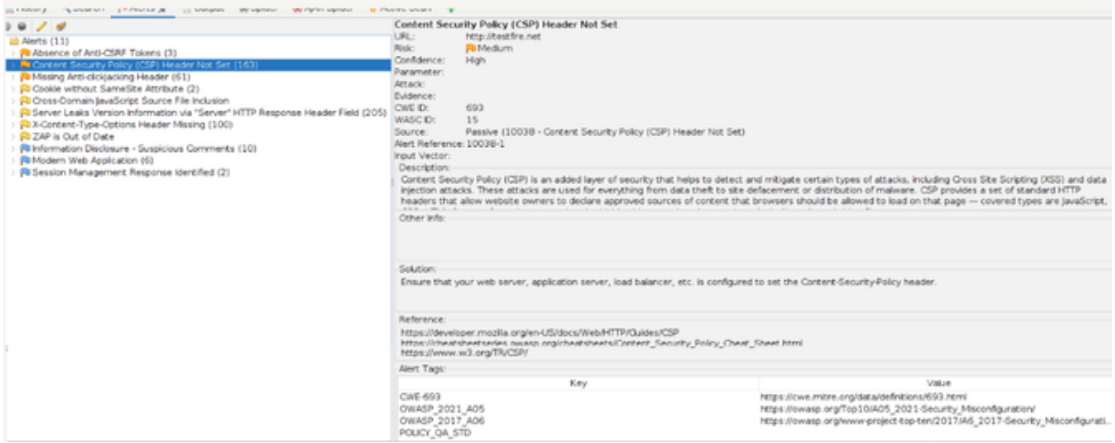


FIGURE 2: MISSING CONTENT SECURITY POLICY (CSP)



SECURITY REPORT SUMMARY

The website security headers were analyzed using the **SecurityHeaders scanning tool.**

The overall security rating of the website was:

Security Grade: F

The low grade indicates that several important security headers are missing, which increases the risk of security vulnerabilities.

Figure 1: Security Headers Scan Summary

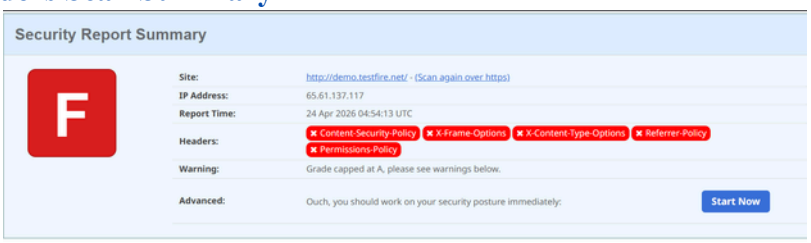
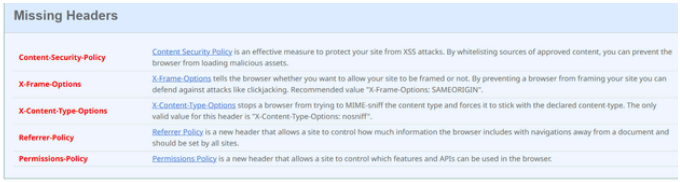


Figure 2: Missing Security Headers



Security Warning Identified
The following warning was generated during the scan:

Site is using HTTP

This indicates that the website is served over HTTP and does not redirect to HTTPS, which means communication between the client and server is not encrypted.

Risk Impact
Using HTTP instead of HTTPS may lead to:

- Data interception
- Man-in-the-Middle (MITM) attacks
- Credential theft
- Session hijacking
-

Recommended Security Improvements

To improve the security configuration of the website, the following actions are recommended:

- Implement Content-Security-Policy header
- Configure X-Frame-Options: SAMEORIGIN
- Add X-Content-Type-Options: nosniff
- Set Referrer-Policy header
- Implement Permissions-Policy header
- Enable HTTPS and redirect HTTP traffic to HTTPS

RISK SUMMARY

Vulnerability	Risk Level
Open HTTP Port	Medium
Server Information Disclosure	Low
Missing Content Security Policy	Medium
Absence of Anti-CSRF Tokens	Medium
Missing Anti-clickjacking Header	Low
Insecure Cookie Configuration	Medium

Risk Level	Number of Alerts
High	0
Medium	4
Low	6
Informational	4
False Positives:	0

Security Recommendations

Based on the security analysis performed using OWASP ZAP, SecurityHeaders, and Nmap, the following recommendations are suggested to improve the security of the web application:

- Implement HTTPS to encrypt communication between users and the server.
- Add missing security headerssuch as:
- Content-Security-Policy (CSP)
- X-Frame-Options
- X-Content-Type-Options
- Referrer-Policy
- Permissions-Policy
- Configure cookies with Secure, HttpOnly, and SameSite attributes to protect session data.
- Hide server version information to prevent attackers from identifying vulnerabilities.
- Restrict access to unnecessary open ports and services.
- Regularly update server software and apply security patches.
- Perform periodic security scans to detect new vulnerabilities.

CONCLUSION

The security assessment of the target website http://demo.testfire.net identified multiple vulnerabilities related to missing security headers, insecure communication over HTTP, and exposed services on open ports.

The website received a security grade of F, indicating weak security configuration. Several vulnerabilities such as missing CSP headers, absence of anti-clickjacking protection, and insecure cookie settings were detected during the scan.

By implementing the recommended security controls such as enabling HTTPS, adding proper security headers, securing cookies, and managing open ports, the overall security of the web application can be significantly improved and protected against common web-based attacks.